

Secure Chat-Based Environment Using AI-Based IDS

Prepared by:

William Rateb Albeni

Supervised by:

Dr. Wassim Aljuneidi

Year

2025-2026

Abstract

The rapid evolution of digital communication necessitates robust security mechanisms to protect sensitive user data. This project aims to design and implement a secure, real-time chat application utilizing a modern N-Tier architecture. To achieve this objective, a full-stack system was developed, comprising a React-based frontend and a C# .NET Core backend. Real-time bidirectional communication and dynamic message status updates (sent, delivered, read) were achieved using SignalR technology. Furthermore, to ensure data confidentiality against unauthorized database access, a Data-at-Rest encryption model was implemented using the Advanced Encryption Standard (AES) with a server-managed master key. Experimental testing demonstrated the system's high efficiency in delivering real-time messages with minimal latency, while successfully protecting stored data in the SQL Server database. The proposed architecture provides a practical balance between stringent security requirements and functional usability, offering a reliable platform for secure enterprise communication.

Keywords: Secure Chat, Real-Time Communication, SignalR, Data-at-Rest Encryption, N-Tier Architecture.

يحتّم التطور السريع للاتصالات الرقمية وجود آليات أمنية قوية لحماية بيانات المستخدمين الحساسة. يهدف هذا المشروع إلى تصميم وتنفيذ تطبيق محاكاة أمن في الوقت الفعلي باستخدام معمارية (N-Tier) حديثة. ولتحقيق هذا الهدف، تم تطوير نظام متكامل يتكون من واجهة أمامية (Frontend) مبنية باستخدام (React) وبرمجة (Backend) باستخدام (C# .NET Core). تم تحقيق الاتصال ثنائي الاتجاه في الوقت الفعلي وتحديثات حالة الرسائل الديناميكية (مرسلة، تم التسليم، مقروءة) باستخدام تقنية (SignalR). علاوة على ذلك، ولضمان سرية البيانات ضد الوصول غير المصرح به إلى قاعدة البيانات، تم تنفيذ نموذج تشفير البيانات في حالة السكون (Data-at-Rest) باستخدام معيار التشفير المتقدم (AES) مع مفتاح رئيسي يدار من قبل الخادم. أثبتت الاختبارات التجريبية الكفاءة العالية للنظام في تسليم الرسائل في الوقت الفعلي بأقل زمن انتقال، مع حماية البيانات المخزنة بنجاح في قاعدة بيانات (SQL Server). توفر المعمارية المقترحة توازناً عملياً بين المتطلبات الأمنية الصارمة وقابلية الاستخدام الوظيفي، مما يقدم منصة موثوقة للاتصالات المؤسسية الآمنة.

الكلمات المفتاحية: محاكاة أمنية، الاتصال في الوقت الفعلي، تقنية SignalR، تشفير البيانات في حالة السكون، المعمارية متعددة الطبقات

Chapter One

Introduction

1-1. Preface

The rapid advancement of digital communication technologies has fundamentally transformed how individuals and organizations exchange information. In the modern era, real-time messaging platforms have become the backbone of daily operations, necessitating highly responsive and available network infrastructures. However, this heavy reliance on digital communication introduces critical vulnerabilities, making information security a primary concern. The increase of cyber threats, ranging from data interception in transit to advanced database breaches, demands the implementation of robust security architectures. Consequently, modern software engineering must bridge the gap between seamless real-time communication and strict data protection mechanisms. This project explores the development of a secure chat application that integrates modern web technologies, specifically a React-based frontend and an ASP.NET Core backend, with real-time bidirectional communication protocols and robust cryptographic standards.

1-2. Scientific Problem and Project Justifications

A fundamental challenge in modern network security is balancing absolute data privacy with functional usability. Traditional communication systems often store user messages in plaintext within databases, rendering them highly susceptible to mass data exfiltration if the database server is exposed. Conversely, implementing strict End-to-End Encryption (E2EE) prevents the server from accessing the data entirely, which complicates essential server-side functionalities such as message search capabilities, and centralized auditing required in enterprise environments. The scientific problem addressed in this project is the vulnerability of stored communication data to unauthorized database access. The justification for this project lies in the necessity to protect sensitive information from database leaks while maintaining server-side functional flexibility. To resolve this, the project adopts a Data-at-Rest encryption architecture using the Advanced Encryption Standard (AES) with server-managed keys. This approach ensures that if the database is breached, the exfiltrated data remains encrypted and unreadable, providing a crucial layer of security known as Defense in Depth.

1-3. Project Objectives

The primary objective of this project is to design and implement a secure, real-time communication platform based on a clean N-Tier architecture. This overarching goal is achieved through the following specific objectives:

- Developing a responsive frontend using React and a robust backend utilizing C# .NET Core.
- Enforcing a strict N-Tier architecture (Presentation, Business Logic, and Data Access layers) to ensure code maintainability, separation of concerns, and system scalability.
- Integrating SignalR technology to facilitate real-time, bidirectional communication, ensuring minimal latency in message delivery.
- Securing sensitive data by applying Data-at-Rest encryption using AES, preventing unauthorized access to the underlying SQL Server database.
- Securing data in transit by enforcing HTTPS/TLS protocols, mitigating the risk of Man-in-the-Middle (MITM) attacks.

1-4. Previous Studies and State-of-the-Art

Historically, early internet relay chat (IRC) protocols and fundamental messaging applications operated without built-in encryption, leaving data exposed both in transit and at rest. Subsequent studies and industrial advancements led to the widespread adoption of the Transport Layer Security (TLS) protocol, which successfully mitigates interception during data transmission. Recently, the industry has diverged into two primary architectural models for data protection. The first model is End-to-End Encryption (E2EE), utilized by applications like WhatsApp and Signal, which provides zero-knowledge privacy but limits server utility. The second model, which this project builds upon, is the Enterprise Encryption Architecture (Encryption at Rest), utilized by platforms such as Slack, Microsoft Teams, and cloud-based Telegram. State-of-the-art implementations in this domain utilize symmetric encryption algorithms, predominantly AES-256, combined with secure key management practices. By separating the cryptographic keys from the physical database storage, these modern systems achieve a high level of security against database theft while preserving the server's ability to process and synchronize data efficiently across multiple user devices.

1-5. Challenges

Developing a comprehensive secure chat system presents several technical and architectural challenges. A primary challenge is the seamless integration of real-time protocols (SignalR) with a stateless HTTP architecture. Managing client connection states and ensuring accurate, instant synchronization of message delivery statuses across disconnected or intermittently connected clients requires complex event handling and state management. Furthermore, strictly maintaining the N-Tier architectural pattern gives a challenge, as it necessitates the careful transfer of Data Transfer Objects (DTOs) between layers without exposing the underlying database context or

entity models to the presentation layer. Additionally, securely managing the database master key and ensuring cryptographic operations do not introduce significant latency into the real-time communication flow required correct optimization.

1-6. Practical Applications

The architecture and methodologies developed in this project have significant practical applications, particularly within enterprise and organizational environments. The implementation of server-managed Data-at-Rest encryption makes this system highly suitable for internal corporate communications, where administrators require the ability to audit and synchronize data, but must simultaneously protect the organization from external database breaches. Furthermore, the model is applicable to sectors requiring strict regulatory compliance regarding data storage, such as healthcare communication portals and financial advisory services, where data integrity, real-time responsiveness, and defense against database theft are critical operational requirements.

1-7. Chapter Summary

This chapter provided a comprehensive introduction to the project, outlining the context of modern secure communications. The scientific problem regarding database vulnerabilities was identified, justifying the adoption of a Data-at-Rest encryption model. The specific objectives of implementing an N-Tier, real-time, and encrypted application were detailed. Additionally, the chapter reviewed the state-of-the-art approaches in the field, highlighted the primary technical challenges encountered during development, and discussed the practical applications of the proposed system.

Chapter Two

Theoretical Framework

2-1. Preface

This chapter builds the theoretical foundations and academic concepts necessary for developing a secure communication system. It explores the underlying principles of cryptographic protocols, real-time system architectures, and the nature of cyber threats such as Man-in-the-Middle attacks.

2-2. Cryptographic Protocols and Data Protection

Cryptography is the fundamental science of securing information and communications through mathematical codes, ensuring that only intended recipients can access and process the data. Modern secure messaging platforms use advanced encryption protocols to protect transmitted data from interception by malicious actors. Theoretical approaches to data security differentiate between End-to-End Encryption (E2EE) and Enterprise Encryption architectures. In Enterprise settings, Data-at-Rest encryption relies on server-managed keys to encrypt stored data, providing a practical balance between security against database breaches and essential operational usability. A widely adopted standard for this purpose is the Advanced Encryption Standard (AES), a symmetric block cipher utilized to securely encrypt sensitive message payloads before they are stored in the database.[2]

2-3. Data Integrity and Authentication Mechanisms

Data integrity refers to the assurance that information remains accurate, consistent, and unaltered during both storage and transmission. Detecting unauthorized modifications requires algorithms capable of evaluating structural data integrity in real-time. Beyond securing messages in transit, ensuring data integrity at the database level is important for secure user authentication. This is achieved through cryptographic hashing functions, such as Bcrypt, which transform plaintext user passwords into irreversible hash values. By applying a unique cryptographic salt to each password before hashing, the system effectively prevents brute-force and dictionary attacks, ensuring that even if database records are compromised, the actual user credentials remain hard to retrieve and mathematically protected.[4]

2-4. Threat Models and Adversarial Attacks

A critical vulnerability in network communications is the Man-in-the-Middle (MITM) attack, where malicious entities intercept and modify the data flowing between communicating users. Defending against these intrusions requires platforms capable of safeguarding conversations from unauthorized access and interception. In modern contexts involving automated systems, MITM threats have evolved into adversarial attacks that intercept and manipulate user messages before they reach backend processors. These adversarial frameworks operate by injecting false

information, misleading instructions, or unrelated noise into the communication process. Such attacks exploit the input sensitivity of systems, weakening the actual correctness of generated responses and highlighting the necessity for monitoring response uncertainty to detect potential compromises.[5]

2-5. Real-Time Communication Architectures

The development of highly responsive secure messaging solutions relies on modular software architectures. Client-side interfaces are typically constructed using modern web frameworks to provide a seamless user experience, while backend processing manages data, productivity, and validation. To enable real-time bidirectional communication, these platforms utilize socket-based technologies, such as WebSockets or Socket.io, which simplify instant message transmission and dynamic status updates. Cloud-based backends, such as Firebase, offer scalable secure user authentication, real-time database synchronization, and encrypted storage capabilities.[1]

2-6. Chapter Summary

This chapter provided an overall review of the theoretical models and algorithms that constitute modern secure communication frameworks. It detailed the mechanics of MITM and adversarial attacks, underscoring the vulnerabilities present in real-time data transmission, and the theoretical foundations of N-Tier architectures.

Chapter three

Environment Setup and Implementation

3-1. Preface

This chapter provides a detailed description of the practical implementation of the secure chat project. It outlines the development environment, software components, and the specific configurations applied to build the system. A major focus is placed on the practical execution of the security mechanisms, detailing how data is protected at rest and in transit, how user identities are secured, and how system availability is maintained. The configurations are designed to meet high security standards while keeping the application functional and efficient.

3-2. Development Environment and Tools

To implement the proposed architecture, a modern and robust set of development tools and frameworks was utilized. The backend services and application logic were developed using C# and the ASP.NET Core framework, providing a high-performance environment suitable for handling real-time operations. The database management system selected was Microsoft SQL Server, used to store user profiles and encrypted messages. For the frontend, React.js was chosen with Vite as the build tool, ensuring a fast, responsive, and secure user interface.

3-3. Data Security at Rest (Encryption at Rest)

A primary security requirement for the chat application is to protect sensitive messages stored in the database from unauthorized access, especially in the event of a database leak or physical server compromise. To achieve this, a Data-at-Rest encryption strategy was implemented using the Advanced Encryption Standard (AES), a widely trusted symmetric encryption algorithm.

In this implementation, the backend server acts as the central authority for encrypting and decrypting data before it reaches the SQL Server database. A highly secure key, named the `DbMasterKey`, was generated and configured within the server's environment settings (`appsettings.json`).

When a message is received by the server, the application logic uses the `DbMasterKey` to encrypt the message content using AES before executing the database INSERT command. Consequently, the database only stores the ciphertext. When a user requests to view their messages, the server retrieves the ciphertext, decrypts it using the same `DbMasterKey`, and sends the readable text back to the authorized user. This separation of the storage medium (SQL Server) and the encryption key (managed by the ASP.NET Core server) adds a strong layer of defense. If an attacker successfully

steals the database files, they cannot read the messages without also compromising the backend server to obtain the DbMasterKey.

This figure shows the AES encryption process before saving to the database:

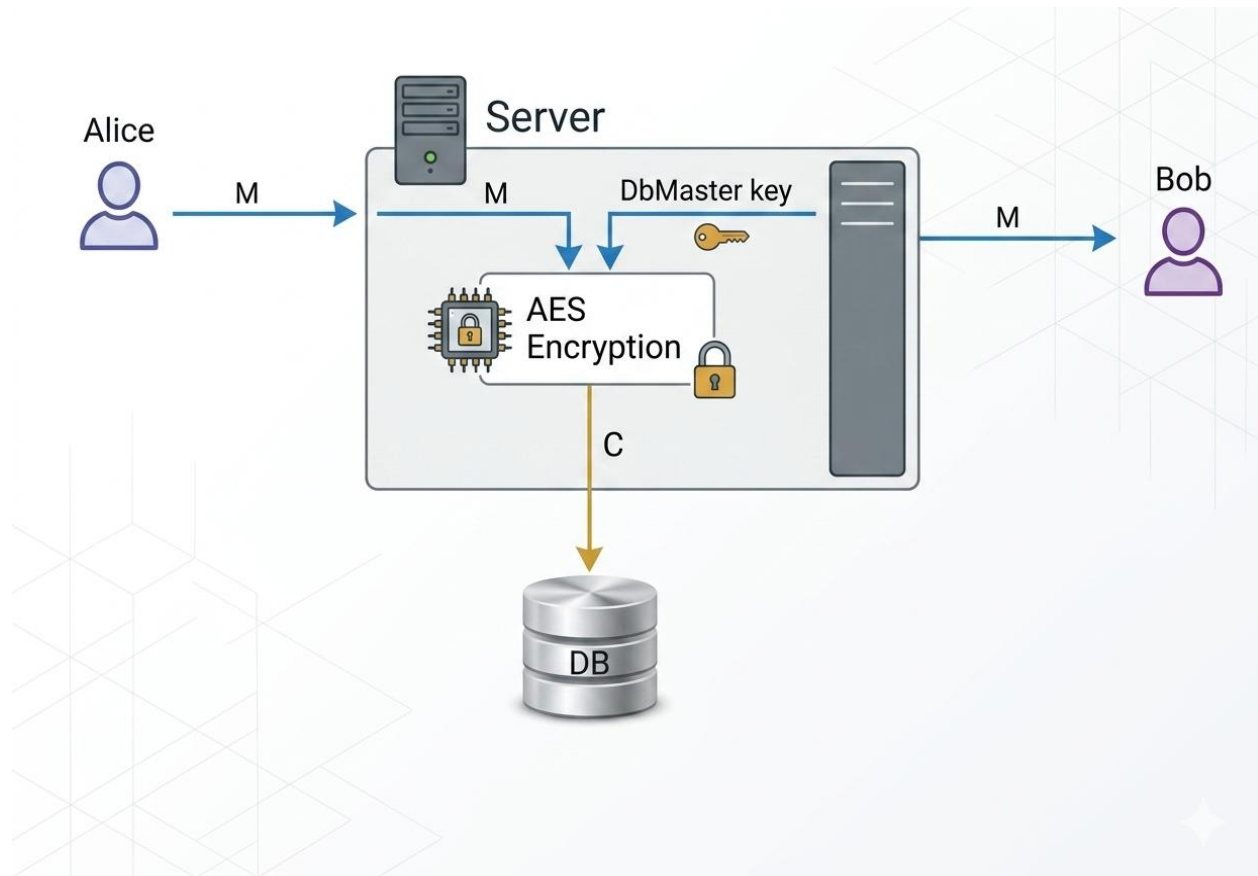


Figure 3-1: AES Encryption Process

3-4. Password Security and Integrity (Hashing)

Protecting user credentials is as critical as protecting the messages. Passwords must never be stored in plain text, nor should they be encrypted, as encryption can be reversed. Instead, a strong cryptographic hashing mechanism was implemented to ensure password integrity and security.

The chosen hashing algorithm for this project was **Bcrypt**. Bcrypt is specifically designed for password hashing because it combines an adaptive cost factor, making the hashing process intentionally slow. This slowness is a critical defense mechanism against brute-force and dictionary attacks, as it makes guessing passwords computationally expensive for attackers. Additionally, Bcrypt automatically generates a unique random "salt" for every password. This salt ensures that even if two users have the exact same password, their resulting hashes will look completely different in the database, protecting against pre-computed hash attacks (Rainbow Tables).

To increase the security even further, an additional layer known as a **Pepper** was implemented. A pepper is a long, secret cryptographic key that is securely stored in the backend server, completely separate from the database. Before a user's password is hashed with Bcrypt, the pepper is appended to the password.

The practical execution flow operates as follows: First, the user inputs their password. Second, the backend server combines the password with the secret pepper. Third, the combined string is hashed using Bcrypt with its unique salt. Finally, only the resulting hash is stored in the SQL Server database. This implementation guarantees that if a hacker tries to steal the database, they still cannot crack the passwords because they do not have the secret pepper, which remains safely isolated in the application server.

Validating the password for user is done as follows: First, when logging in the system, the user password is inserted, BCrypt algorithm takes the password and add the pepper to it. Second, the hash process is applied on the combination, then the user's salt is being retrieved from the database and added it to the front of the previous hash. Finally, the resulting hash is compared with the hash in the database giving a corresponding action.

This figure shows the password storing process and BCrypt workflow:

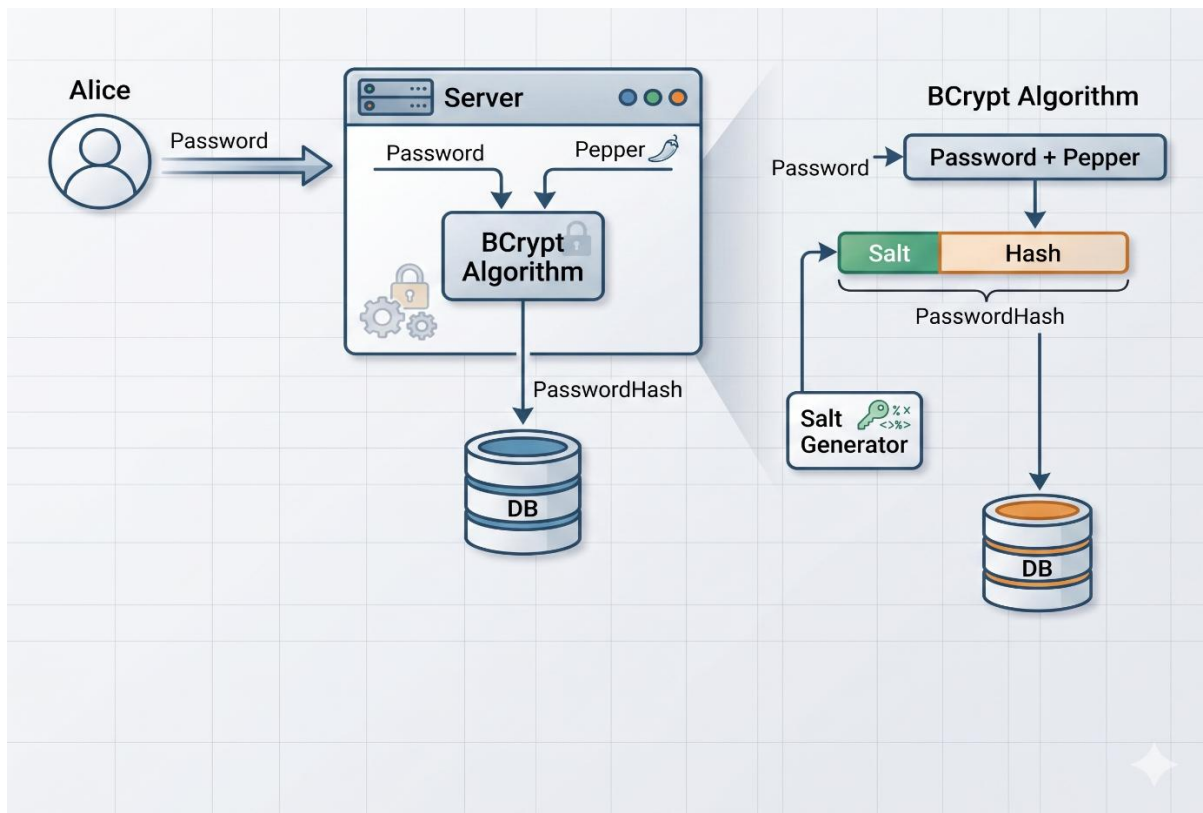


Figure 3-2: BCrypt Algorithm Process

And the following figure shows the identification and password validating process:

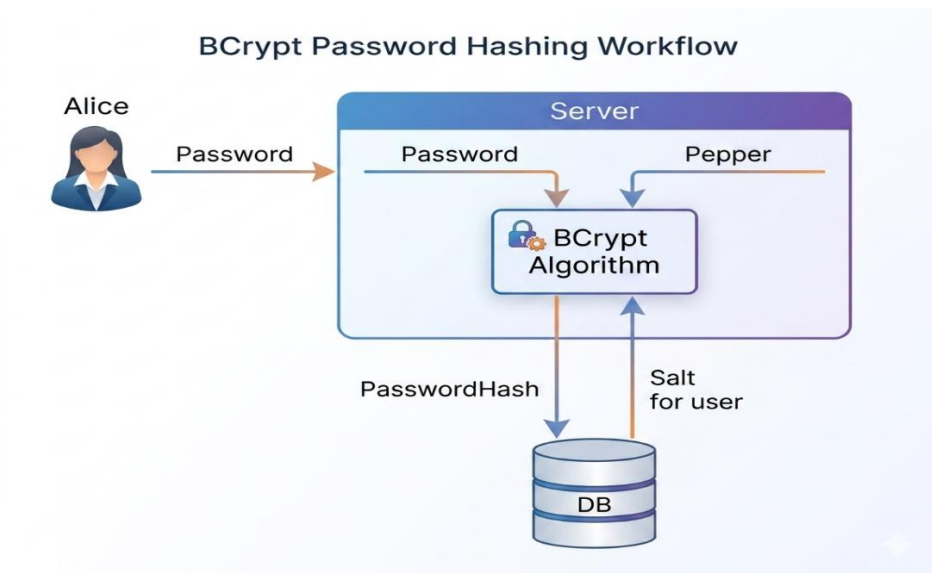


Figure 3-3: Identification/ Password Validating

3-5. Data Security in Transit (Encryption in Transit)

While securing data at rest is crucial, protecting data as it travels across the network is equally important to prevent eavesdropping and Man-in-the-Middle (MITM) attacks. To achieve this, strict Encryption in Transit policies were enforced across the entire application.

Hypertext Transfer Protocol Secure (HTTPS) was configured and mandated for both the React frontend and the ASP.NET Core backend. At the network level, HTTPS secures the communication over Layer 4 (the Transport Layer) by utilizing the Transport Layer Security (TLS) protocol. By enforcing HTTPS, all HTTP headers, request bodies, and server responses are fully encrypted before leaving the device. The backend was explicitly configured to reject any unencrypted HTTP requests, automatically redirecting them to the secure HTTPS port. This implementation ensures that even if an attacker successfully intercepts the network traffic, they will only capture unreadable, encrypted data packets.

This figure shows the HTTPS traffic form:

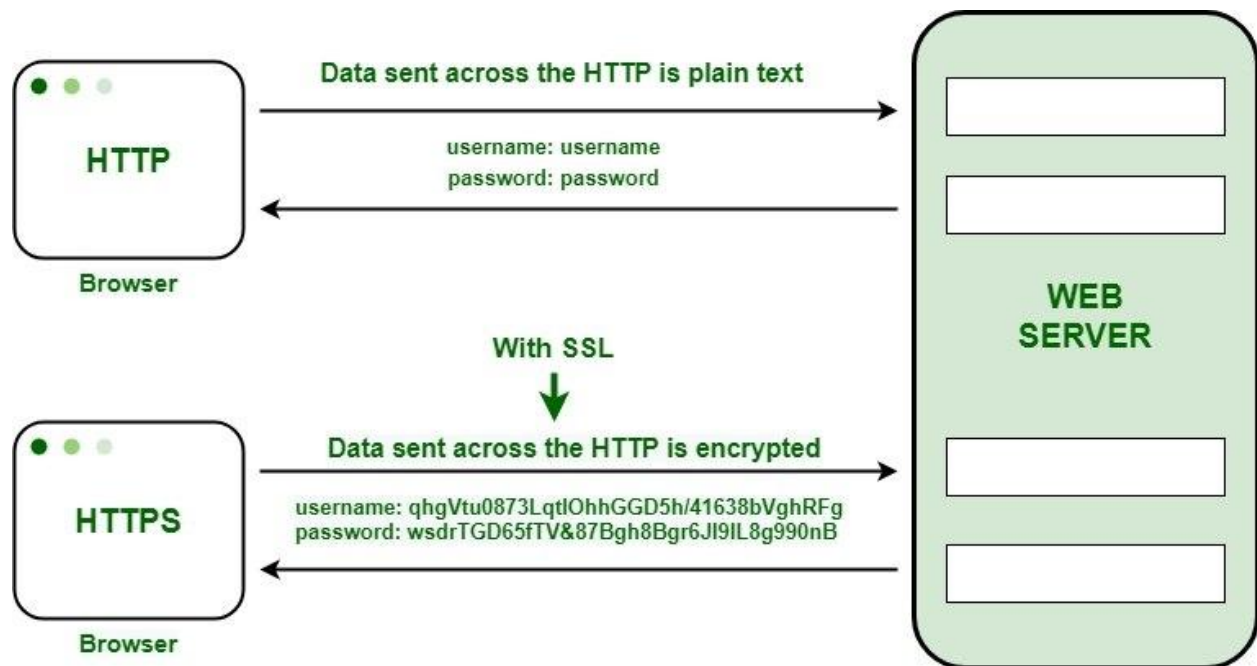


Figure 3-4: HTTPS traffic

3-6. Advanced Data Protection (Hybrid Encryption: AES + RSA)

To provide an additional layer of security beyond the transport layer, an application-layer Hybrid Encryption model was implemented. This model combines the performance efficiency of symmetric encryption with the secure key distribution capabilities of asymmetric encryption, establishing a highly secure channel for message data.

The mechanism utilizes both the Advanced Encryption Standard (AES) and the Rivest-Shamir-Adleman (RSA) algorithms. AES is exceptionally fast and is optimally suited for encrypting the actual content of the chat messages. However, sharing the AES key securely over a network gives an important challenge. To resolve this, RSA is utilized. The process is executed as follows:

First, a dynamic, random AES session key is generated for the message payload. The message is then encrypted using this AES key. Next, the AES key itself is encrypted using the recipient's public RSA key. Both the encrypted message payload and the encrypted AES key are transmitted to the server. Upon reception, the recipient utilizes their private RSA key to decrypt the AES key, which is used to decrypt the original message. This hybrid approach guarantees maximum security for data payloads, ensuring that only the intended recipient can read the message, without compromising real-time communication speed.

This figure demonstrates the hybrid encryption process:

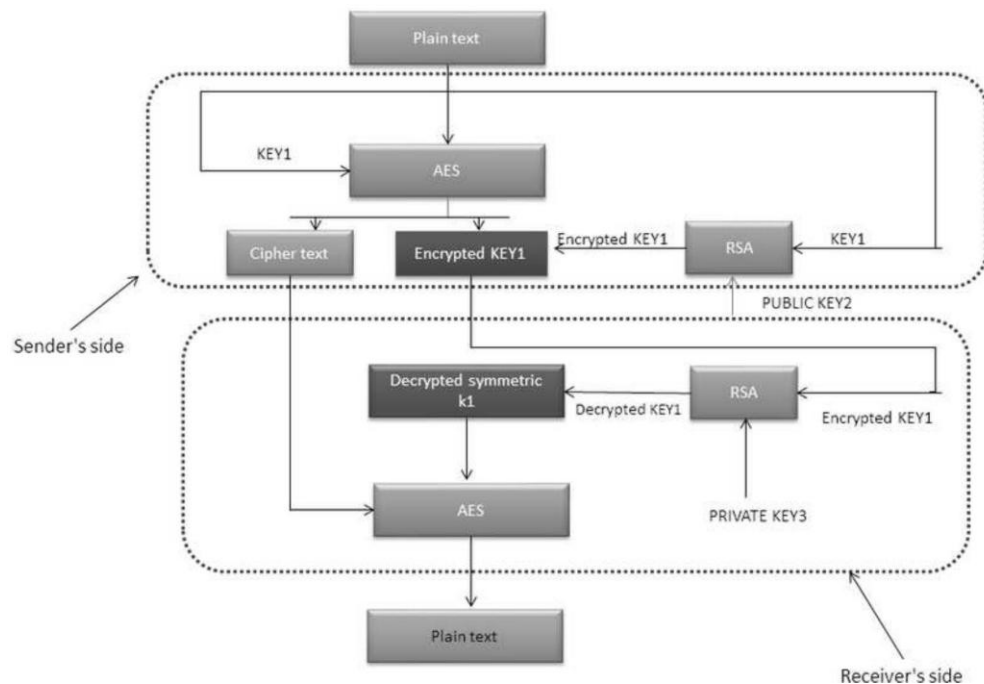


Figure 3-5: Hybrid Encryption

3-7. Achieving System Availability

In the domain of information security, Availability is a core element alongside Confidentiality and Integrity. It ensures that the secure chat application remains operational, reliable, and accessible to authorized users whenever needed. To achieve high availability, several practical configurations were integrated into the system.

For the real-time communication managed by SignalR, automatic reconnection logic was implemented on the client side. In the event of a temporary network drop or instability, the frontend application automatically attempts to restore the WebSocket connection smoothly, without requiring manual user involvement or application restarts. On the backend, the adoption of a clean N-Tier architecture ensures that system components are loosely coupled. Consequently, a failure in one specific module (e.g., a specific business logic service) is less likely to cause a complete server crash. Additionally, database connection was configured within the Entity Framework to automatically retry failed database operations caused by the passing network glitches, minimizing system downtime and ensuring a continuous user experience.

3-8. Chapter Summary

This chapter detailed the practical setup and the security implementations of the project. It outlined the configuration of the development environment and highlighted the methodologies utilized to secure data at rest via AES and the DbMasterKey. Furthermore, the techniques for password hashing using Bcrypt combined with a secret pepper were explained to demonstrate database integrity. The chapter also discussed the enforcement of HTTPS for securing data in transit across Layer 4, and the implementation of a robust hybrid AES-RSA encryption model for payload protection. Finally, the practical steps taken to guarantee system availability and real-time connection flexibility were presented.